Self-Check

7. The following ports were listed as open during a recent port scan. Which one is no longer used except by legacy software and should be closed?
   a. 22
   b. 53
   c. 139
   d. 443
8. You sent a coworker a .exe file to install an app on their computer. What information should you send your coworker so they can ensure the file has not been tampered with in transit?
   a. Public encryption key
   b. Hash of the encryption key
   c. Private encryption key
   d. Hash of the file
9. What can protect your company from a lawsuit if data is recovered from a discarded device?
   a. CEED
   b. PCI DSS
   c. GDPR
   d. DLP

☐ Check your answers at the end of this chapter.

Summary

Section 10-1: Security Risks

- A weakness of a system, process, or architecture that could lead to compromised information or unauthorized access is known as a vulnerability. The act of taking advantage of a vulnerability is known as an exploit.
- Social engineering involves manipulating social relationships to gain access. Common types of social engineering include phishing, baiting, quid pro quo, dumpster diving, tailgating, piggybacking, and shoulder surfing.
- A DoS (denial-of-service) attack occurs when legitimate users are unable to access normal network resources, such as a web server, because of an attacker's intervention. Several DoS subtypes include DDoS (distributed DoS) attack, DRDoS (distributed reflection DoS) attack, amplified DRDoS attack, PDoS (permanent DoS) attack, and friendly DoS attack.
- Common technology-based attacks and vulnerabilities include on-path attacks, deauth (deauthentication) attacks, insecure ports and protocols, FTP bounce, DNS poisoning, and back doors.
- Malware is a generalized term that refers to many kinds of malicious software, including virus, Trojan, worm, bot, and ransomware.

Section 10-2: Risk Assessment and Management

- Effective risk management happens from two complementary perspectives: the network layer and the business layer. A security risk assessment evaluates threats to and vulnerabilities of the network. A business risk assessment evaluates the impact of potential threats on business processes.
- A vulnerability assessment is used to identify vulnerabilities in a network. Pen (penetration) testing takes advantage of hacking techniques to identify weaknesses and the extent of those weaknesses. During a red team–blue team exercise, the red team conducts the attack, and the blue team attempts to defend the network.
- Scanning tools—such as Nmap, Nessus, and Metasploit—can provide useful insights into your network's weaknesses that need attention. Used by hackers (or more likely, by bots) these tools can instead lead to compromised security.
- An IDS (intrusion detection system) is a stand-alone device, an application, or a built-in feature running on a workstation, server, switch, router, or firewall. It monitors network traffic, generating alerts about suspicious activity.

- Although an IDS can only detect and log suspicious activity, an IPS (intrusion prevention system) stands inline between the attacker and the targeted network or host where it can prevent traffic from reaching that network or host.
- A honeypot is a decoy system that is purposely vulnerable and filled with what appears to be sensitive (though false) content. In more elaborate setups, several honeypots might be connected to form a honeynet.

Section 10-3: Device Hardening

- Besides securing network devices from external tampering, you can take many steps to secure the device from network- or software-supported attacks as well. These practices are called device hardening. There are many layers of defense you can implement, although the options vary from one device to another.
- Updates to applications, operating systems, and device firmware address several issues, including fixing bugs, adding new features, and closing security gaps. Because of the urgency of protecting networks and data from being compromised, security gaps are often addressed in smaller, more frequent updates called patches.
- Insecure services and protocols, such as Telnet and FTP, should be disabled in a system whenever possible. Leaving these software ports open and services running practically invites an intrusion because it's so easy to crack into a system through these open doors.
- Because default credentials are so commonly used, they're also extremely insecure. When configuring a device, make it a habit to change the default administrative credentials before you do anything else and record this information in a safe place. When you do so, avoid common usernames and passwords.
- When implementing anti-malware software on devices and the network, one of your most important decisions is where to install the software. Some scenarios include host-based, server-based, network-based, or cloud-based.
- A rogue DHCP server running on a client device could be used to implement an on-path attack by configuring the attacker's IP address as the victim computers' default gateway. Alternatively, the attacker could give their IP address as the DNS server and then spoof websites. DHCP messages should be monitored by enabling DHCP snooping on a switch.
- ARP performs no authentication, and so it is highly vulnerable to attack. As a result, attackers can use ARP spoofing, also called ARP poisoning or ARP cache poisoning, to send faked ARP replies that alter ARP tables in the network. DAI (dynamic ARP inspection) can be configured on a switch to protect against ARP spoofing attacks.
- IT assets of all kinds must be carefully tracked both during and after their service time, as your company is legally responsible for the data contained on those devices even after you stop using them. Disposal services provide a CEED (Certificate of Electronic Equipment Destruction), which serves as legal protection should data later be recovered from your devices. This kind of documentation must be presented during some types of audits.

Key Terms

For definitions of key terms, check the Glossary.

ARP spoofing
botnet
business process
business risk assessment
C&C (command-and-control) server
CEED (Certificate of Electronic Equipment Destruction)
CVE (Common Vulnerabilities and Exposures)
DAI (dynamic ARP inspection)
data breach
data localization
DDoS (distributed DoS) attack
device hardening
DHCP snooping
DLP (data loss prevention)
DNS poisoning
DoS (denial of service) attack
dumpster diving
exploit
FIM (file integrity monitoring)
GDPR (General Data Protection Regulation)
hacker
honeynet
honeypot
IDS (intrusion detection system)
insider threat
IPS (intrusion prevention system)
malware (malicious software)
on-path attack
PCI DSS (Payment Card Industry Data Security Standards)
pen (penetration) testing
phishing
port mirroring
port scanner
posture assessment
principle of least privilege
privileged access
ransomware
red team–blue team exercise
risk
rogue DHCP server

sandbox
security audit
security risk assessment
shoulder surfing
signature
social engineering
tailgating
TAP (test access point)
threat
vulnerability
vulnerability assessment
zero-day exploit

Acronyms Checklist

The acronyms in Table 10-1 are listed in the CompTIA Network+ objectives and could appear on the Network+ exam. This means that exam questions might use any of these acronyms in context so that you must know the meaning of the acronym in order to answer the question correctly. Make sure you're familiar with what each acronym stands for and the general concept of the term itself. All these acronyms are used in context in this chapter.

Table 10-1 Chapter 10 acronyms

Acronym	Spelled out
DDoS	distributed DoS
DLP	data loss prevention
DoS	denial of service
GDPR	General Data Protection Regulation
IDS	intrusion detection system
IPS	intrusion prevention system
PCI DSS	Payment Card Industry Data Security Standards

Review Questions

1. Which type of DoS attack orchestrates an attack bounced off uninfected computers?
   a. FTP bounce
   b. Ransomware
   c. DRDoS attack
   d. PDoS attack
2. What information in a transmitted message might an IDS use to identify network threats?
   a. Signature
   b. FIM
   c. Port mirroring
   d. ACL
3. What type of attack relies on spoofing?
   a. Deauth attack
   b. Friendly DoS attack
   c. Tailgating
   d. Pen testing
4. Which device would allow an attacker to make network clients use an illegitimate default gateway?
   a. Cipher lock
   b. DHCP server
   c. TAP
   d. Honeypot
5. Leading up to the year 2000, many people expected computer systems the world over to fail when clocks turned the date to January 1, 2000. What type of threat was this?
   a. Ransomware
   b. Virus
   c. Logic bomb
   d. Worm
6. Which of the following attack simulations detect vulnerabilities and attempt to exploit them? Choose TWO.
   a. Red team–blue team exercise
   b. Vulnerability assessment
   c. Security audit
   d. Pen testing
7. What is the difference between a vulnerability and an exploit?
   a. A vulnerability takes advantage of an exploit.
   b. A vulnerability is the likelihood that a risk will be exploited.
   c. An exploit takes advantage of a vulnerability.
   d. A risk is the likelihood that a vulnerability will be exploited.

8. What is the first phase of the social engineering attack cycle?

   a. Quid pro quo
   b. Research
   c. Phishing
   d. Building trust

9. What type of process might identify that Telnet is running on a server?

   a. Pen testing
   b. IPS
   c. IDS
   d. Port scanning

10. What characteristic of ARP makes it particularly vulnerable to being used in a DoS attack?

   a. ARP passwords are not hashed.
   b. ARP performs no authentication.
   c. ARP messages flow freely through switches.
   d. ARP tables can be altered.

Scenario-Based Questions

Question 10-1

A company accidentally sends a newsletter with a mistyped website address. The address points to a website that has been spoofed by hackers to collect information from people who make the same typo. What kind of attack is this?

a. Phishing
b. Tailgating
c. Quid pro quo
d. Baiting

Question 10-2

Your organization has just approved a special budget for a network security upgrade. What procedure should you conduct to develop your recommendations for the upgrade priorities?

a. Data breach
b. Security audit
c. Exploit
d. Posture assessment

Question 10-3

A former employee discovers six months after they start work at a new company that their account credentials still give them access to their old company's servers. They demonstrate their access to several friends to brag about their cleverness and talk badly about the company. What kind of attack is this?

a. Principle of least privilege
b. Insider threat
c. Vulnerability
d. Denial of service

Question 10-4

A neighbor hacks into your secured wireless network on a regular basis, but you didn't give her the password. What loophole was most likely left open?

a. The firmware contains a back door.
b. The default password was not changed.
c. The router has been recruited by a botnet.
d. Her network is using the same credentials as yours.

Hands-on Projects

Note 10-4 | Websites, applications, public cloud platforms, and related account options change often. While the instructions given in these projects were accurate at the time of writing, you might need to adjust the steps or options according to later changes.

Note to Instructors and Students: A rubric is provided for evaluating student performance on these projects. Please see Appendix D.

Project 10-1: Secure a Workstation

Estimated time: 20 minutes
Objective 4.1: Explain the importance of basic network security concepts.
Resources:
- Windows computer with administrative access
- Internet access

Description:
Securing a workstation is one of the most important tasks you will perform when setting up security for an organization or individual. A few simple tweaks to a computer's security configuration will greatly improve its resistance to attack. Follow these steps to require that a user press Ctrl+Alt+Del to log on:

1. Press **Win+R**, and in the Search box, enter **netplwiz**. Write down the usernames displayed in the section labeled "Users for this computer."
2. Click the **Advanced** tab. Under Secure sign-in, check **Require users to press Ctrl+Alt+Delete**. Research this technique online. Why does this setting help increase the workstation's security?
3. Apply the changes and restart the computer to confirm the change.

Follow these steps to secure the computer using a screen saver and sleep mode:

4. Open **Settings**, click **Accounts**, and click **Sign-in options**. Under Additional settings, select **When PC wakes up from sleep**. Note that your options might be different, depending on other settings in your OS.
5. In the Settings menu, click **System**, click **Power** (or **Power & battery**, if using a laptop), and click **Screen and sleep**. Set the Screen timeouts and Sleep timeouts as desired. **Take a screenshot** of these settings; submit this visual with your responses to this project's questions.
6. In the Settings menu, click **Personalization**, and click **Lock screen**. Scroll down and click **Screen saver**. Select a screen saver.
7. Set a wait time. For optimal security, this should be a low number. Check **On resume, display logon screen**. Click **OK** and close all windows.

Follow these steps to require that all users have a password:

8. Press **Win+R**, and in the Search box, enter **gpedit.msc**. The Local Group Policy Editor window opens.
9. Navigate to **Computer Configuration**, **Windows Settings**, **Security Settings**, **Account Policies**, **Password Policy**.
10. Double-click the Minimum password length item. Change the Minimum password length policy to a value higher than zero. How many characters did you require? What was your reasoning in choosing the number?
11. Click **OK** and close all open windows.

Project 10-2: Configure DHCP Snooping in Packet Tracer

Estimated time: 30 minutes

Objective 4.2: Summarize various types of attacks and their impact to the network.

Resources:

- Cisco Packet Tracer

Description:

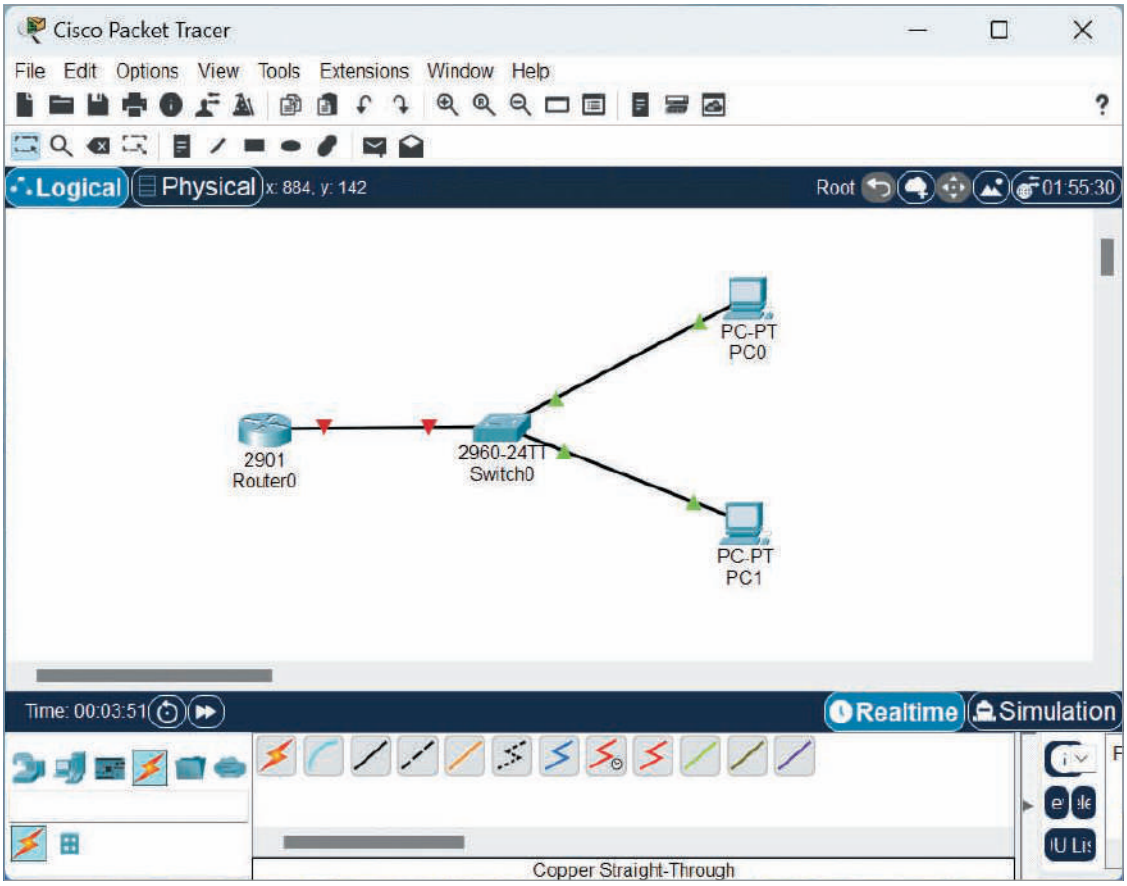
In the chapter, you read about several risks that can come from poorly configured network devices, such as routers and switches. In this project, you'll create a new Packet Tracer network, and then you'll conduct an attack on that network using a rogue DHCP server. You'll then protect the network by configuring DHCP snooping on the switch.

This Packet Tracer project starts with a new network and is *not* intended to build on your Packet Tracer network for the Capstone Projects. For this project, do *not* use your existing Packet Tracer network (most recently worked on in Chapter 9)—you'll come back to that network file in this chapter's Capstone Projects. In this project, start with a new Packet Tracer file to experiment with DHCP snooping. You will *not* need to save this network for future projects or chapters.

Complete the following steps:

1. Open **Cisco Packet Tracer**—make sure you're starting from a new file, not an existing network.
2. Add a 2960 switch, a 2901 router, and two PCs. Connect the devices to the switch using Copper Straight-Through cables (Figure 10-28). Make sure to connect the switch and router using the router's GigabitEthernet0/0 interface.

Figure 10-28 Connect a router, switch, and two PCs



Source: Cisco Systems, Inc.

3. Enter the commands in Table 10-2 to configure the router's interface and a DHCP pool on the router.

Table 10-2 Configure the router with a DHCP pool

Command	Purpose
`enable`	Enters privileged EXEC mode
`configure terminal`	Enters global configuration mode
`interface gigabit0/0`	Enters interface configuration mode for GigabitEthernet0/0
`ip address 192.168.2.1 255.255.255.0`	Assigns network information to the interface
`no shut` and press **Enter** to return to the prompt	Enables the port
`exit`	Returns to global configuration mode
`ip dhcp pool MyPool`	Creates a DHCP pool named MyPool and enters DHCP configuration mode
`network 192.168.2.0 255.255.255.0`	Assigns network information to the DHCP pool
`default-router 192.168.2.1`	Assigns a default gateway to the DHCP pool
`do show ip dhcp pool`	Displays DHCP pool configuration information
`exit`	Returns to global configuration mode

4. On each PC, request a DHCP assignment. In some cases, it might take a couple of tries for the DHCP assignment to succeed. If it still doesn't work, do some troubleshooting to figure out the problem and fix it. What IP address was assigned to each PC? What is the default gateway address for both PCs?

Suppose an attacker brings their own DHCP server to your network. The attacker configures their device as the default gateway so your PCs start sending their traffic to the wrong device. Complete the following steps:

5. Add a server to your workspace. Do NOT yet connect the attacker's server to your network. Make the following configurations to the server first:
   a. Set the server's static IP address to 192.168.2.20/24.
   b. Turn on the server's DHCP service. Set the pool's default gateway address to 192.168.2.20 and its start IP address to 192.168.2.21/24. Be sure to save these settings.
   c. Use a Copper Straight-Through cable to connect the hacker's server to your switch.
6. After the server's connection with the switch activates, at PC0's Command Prompt, enter the command **`ipconfig/release`** and then enter the command **`ipconfig/renew`**. What information does PC0 receive? Which DHCP server did it get its assignment from?

To protect your network, you need to enable DHCP snooping on the switch. This will ensure that DHCP responses can only come from an approved DHCP server. Complete the following steps:

7. Enter the commands in Table 10-3 to configure DHCP snooping on the switch.

Table 10-3 Configure the switch for DHCP snooping

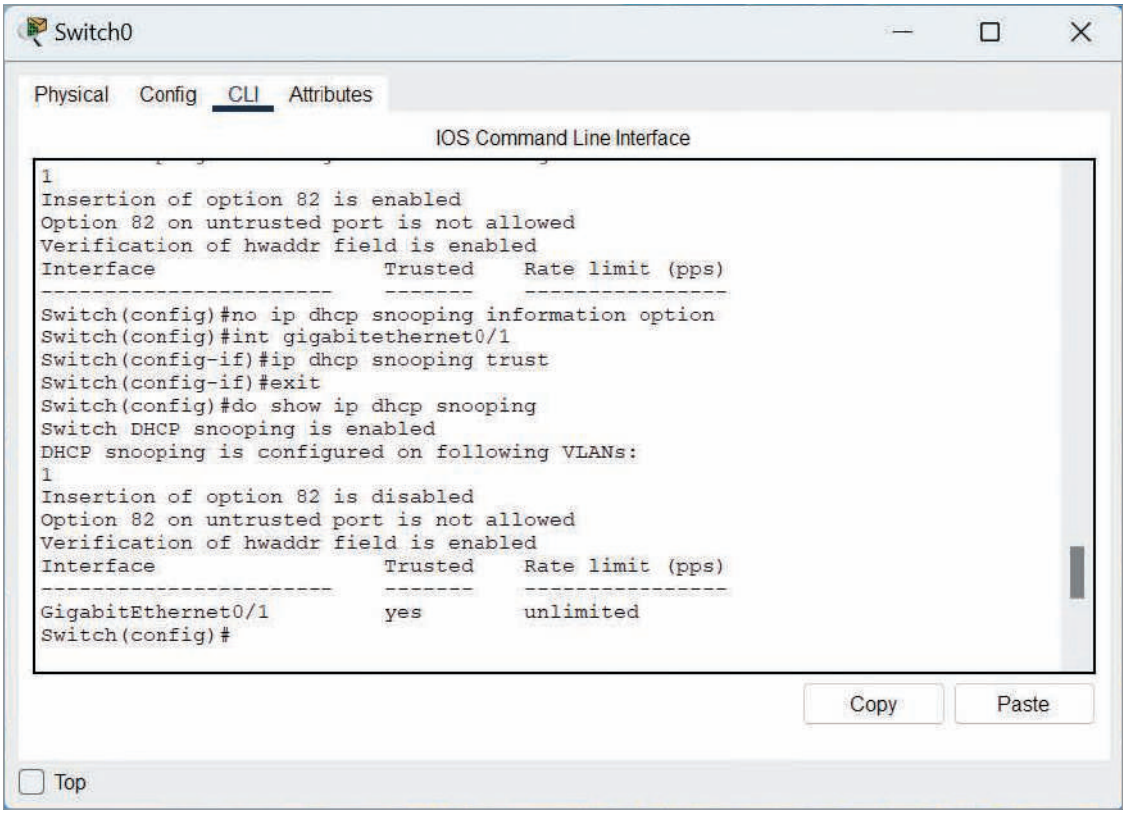
Command	Purpose
enable	Enters privileged EXEC mode
configure terminal	Enters global configuration mode
ip dhcp snooping	Enables DHCP snooping globally on the switch
ip dhcp snooping vlan 1	Enables DHCP snooping for VLAN 1
do show ip dhcp snooping	Displays current DHCP snooping configuration; confirm DHCP snooping is configured for VLAN 1

8. Now that DHCP snooping is enabled on your switch, no DHCP responses are currently allowed because, by default, all ports are untrusted. To test this, at PC0's Command Prompt, enter the command **ipconfig /release** and then enter the command **ipconfig /renew**. What information does PC0 receive?
9. For the legitimate DHCP server to work on your network, you need to tell the switch which port it should trust for DHCP responses. Enter the commands in Table 10-4 to configure a trusted DHCP port on the switch.

Table 10-4 Configure a trusted port on the switch for DHCP responses

Command	Purpose
no ip dhcp snooping information option	Disables the unneeded Option 82 in DHCP snooping
interface gigabitethernet0/1	Enters interface configuration mode for GigabitEthernet0/1, which is connected to the router
ip dhcp snooping trust	Designates this port as a DHCP trusted port because it is attached to the DHCP server
exit	Returns to global configuration mode
do show ip dhcp snooping	Displays current DHCP snooping configuration; confirm configuration matches that shown in Figure 10-29
exit and press **Enter**	Returns to privileged EXEC mode
copy run start and press **Enter** to accept the default filename	Saves the current settings

Figure 10-29 Correct DHCP snooping configuration



Source: Cisco Systems, Inc.

10. Now that DHCP snooping is trusted on the correct port on your switch, DHCP responses should be allowed from the legitimate DHCP server. To test this, at PC0's Command Prompt, enter the command **`ipconfig /release`** and then enter the command **`ipconfig /renew`**. What information does PC0 receive? Which DHCP server did it get its assignment from? How do you know?
11. Confirm that PC1 can also still receive DHCP information from the legitimate DHCP server. Does it work? How do you know?
12. To see the switch's new records for DHCP assignments on the network, on the switch's CLI in privileged EXEC mode, enter the command **`show ip dhcp snooping binding`**. How many addresses are listed in the switch's DHCP snooping binding table? Notice the Type for each record is labeled "dhcp-snooping" to indicate the switch learned this information through DHCP snooping.
13. To see which ports the switch trusts for DHCP responses, on the switch's CLI in privileged EXEC mode, enter the command **`show ip dhcp snooping`**. How many interfaces are listed? How many of these interfaces are trusted?
14. Position your network devices and the switch's CLI console to show your network topology and the output on the switch for Steps 12 and 13. **Take a screenshot**; submit this visual with your responses to this project's questions.
15. Save your project for future reference. Make some notes on your Wikidot website about your activities in Packet Tracer for this project.

Note to instructors: A Packet Tracer solution file is provided for each Packet Tracer project through the Instructors site.

Capstone Projects

Note 10-5 | Websites, applications, public cloud platforms, and related account options change often. While the instructions given in these projects were accurate at the time of writing, you might need to adjust the steps or options according to later changes.

Note to Instructors and Students: A rubric is provided for evaluating student performance on these projects. Please see Appendix D.

Capstone Project 10-1: Configure Router Passwords in Packet Tracer

Estimated time: 45 minutes
Objective 4.3: Given a scenario, apply network security features, defense techniques, and solutions.
Resources:
- Computer with Cisco Packet Tracer installed
- Access to the Packet Tracer network created in Capstone Project 9-2
- Storage space for Packet Tracer network file to be accessed in later projects and chapters
- Internet access

Description:
This Capstone Project picks up where Capstone Project 9-2 left off. When configuring a networking device, one of the very first tasks should be to change the default administrative credentials. In this project, you will use the CLI to configure user accounts and passwords for a router in your Packet Tracer network. Complete the following steps:

1. In **Cisco Packet Tracer**, open your Packet Tracer file from Capstone Project 9-2. If desired, make a backup copy before proceeding.
2. Click **Router3** and click the **CLI** tab. In the IOS CLI pane, press **Enter** to continue.
3. Enter the commands listed in Table 10-5 to change the router's default name.

Table 10-5 Change a router's hostname

Command	Purpose
`enable`	Enables privileged EXEC mode
`configure terminal`	Enters global configuration mode
`hostname R3`	Renames the router from the default to R3. Notice the prompt change.

4. What prompt do you see now?
5. Now you're ready to create a username and password, which will be required to sign into the router's management interface. Enter the commands listed in Table 10-6.

Table 10-6 Set a username and password and check the configuration

Command	Purpose
`username wrigley password cengage`	Creates the user account "wrigley" and requires the password "Cengage" for that account
`line console 0`	Accesses the console port configuration interface (that is, the port you might connect a laptop to using a console cable to configure the router)
`login local`	Configures the router to require a locally configured username and password to log into the router's management interface
end and press **Enter**	Returns to privileged EXEC mode
`logout`	Logs out of the router's interface
Press **Enter** and then log in using the following credentials: Username: `wrigley` Password: `cengage`	Logs back into the router's interface using the new username and password

6. Check the configured username and password in the running-config file. Enter the commands listed in Table 10-7.

Table 10-7 View configurations in the running-config file

Command	Purpose
`enable`	Enables privileged EXEC mode
`show running-config`	Lists the configurations in the running-config file

Note 10-6 | Press **Enter** to advance one line at a time in the running-config file.
Press **Space** to advance one page at a time.
When you're finished, press **Tab** to exit the running-config file.

7. What username and password information are shown in the running-config file? Why is this a problem?
8. Passwords should never be stored in plaintext. There's another way to create a password so the password will be stored more securely. Enter the commands listed in Table 10-8.

Table 10-8 Set a username and secret password and confirm configurations

Command	Purpose
`configure terminal`	Enters global configuration mode
`username maya secret cengage`	Creates the user account "maya" and requires the secret password "cengage" for that account
`do show running-config`	Lists the configurations in the running-config file

9. **Take a screenshot** of the usernames and passwords shown in the running-config file this time; submit this visual with your responses to this project's questions. The password for both accounts is "cengage". Why do these passwords look different in the running-config file?
10. While you're at it, set two more passwords. Either one of these passwords could be required to enable privileged EXEC mode (although in reality, only the last enable password will continue to work). The difference is that one password will be stored in plaintext and the other will be hashed. Enter the commands listed in Table 10-9.

Table 10-9 Set a password and a secret password that can enable privileged EXEC mode

Command	Purpose
`enable password networkplus`	Requires the password "networkplus" to enable privileged EXEC mode
`enable secret comptia`	Requires the password "comptia" to enable privileged EXEC mode
`do show running-config`	Lists the configurations in the running-config file

11. **Take a screenshot** of the enable passwords shown in the running-config file; submit this visual with your responses to this project's questions.
12. You can encrypt existing passwords on a router, rather than having to go back and reconfigure each insecure password. Enter the commands listed in Table 10-10.

Table 10-10 Encrypt existing passwords

Command	Purpose
`service password-encryption`	Encrypts any plaintext passwords
`do show running-config`	Lists the configurations in the running-config file

13. What do you notice now about the two enable passwords? What about the two user account passwords?

Compare the complexity of the encryption for the passwords that were originally stored in plaintext with the passwords that were originally hashed. The secret passwords show a much more complex code. Notice the 5 in front of the secret passwords, which indicates the MD5 hash was used. Also notice the 7 in front of the other passwords. These Type 7 passwords use a weak encryption algorithm that is easily cracked. To explore these processes, complete the following steps:

14. In your browser, go to **packetlife.net/toolbox** and click **Type 7 Reverser**. Copy and paste the Type 7 password string for each of the Type 7 passwords in Packet Tracer into the Type 7 hash box on the website. Note that you will need to select and then right-click each string to copy it into your clipboard instead of using the Ctrl+C shortcut. After pasting each string into the hash box, click **Reverse**. Do the values match your original plaintext passwords?
15. Now try the same process with the Type 5 password strings. What happens this time?

16. To save these configurations, **`exit`** to privileged EXEC mode, enter the command **`copy run start`**, and then press **Enter** again to accept the default filename.
17. Make some notes on your Wikidot website about your activities in Packet Tracer for this project.

Note to instructors: A Packet Tracer solution file is provided for each Packet Tracer project through the Instructors site. Some Packet Tracer projects build on earlier Packet Tracer networks. If needed for one or more students, you can provide a previous project's solution file as a start file for one of these progression projects.

Capstone Project 10-2: Secure Ubuntu Server

Estimated time: 30 minutes

Objective 4.3: Given a scenario, apply network security features, defense techniques, and solutions.

Resources:

- Access to the same computer used to complete Capstone Project 3-1
- Internet access

Description:

In Chapter 3, Capstone Project 3-1, you installed Ubuntu Server in a VM. In this project, you'll perform tasks to secure your Ubuntu Server system. To do this, you will first update your OS and practice working with running services listening on the network. Then you'll learn some basic commands in iptables (Ubuntu Server's default firewall), configure a couple of firewall rules, and save the rules in a file. Complete the following steps:

1. Start your Ubuntu Server VM and log in. Refer to your notes in Wikidot and your account information in Bitwarden if you need a refresher on where this VM is saved and how to access the user account. You'll need your password several times throughout this project, so keep it handy.
2. First, update your Ubuntu Server OS. To do this, enter the command **`sudo apt update`** and enter your password. After that process completes, enter the command **`sudo apt upgrade`** and enter **`y`** to continue, which will finish all updates. This process could take a few minutes and might require a reboot.

Let's install the web server software Nginx so you can practice securing your server. Complete the following steps:

3. Enter **`sudo ss -atpu`** to see running services on your server. How many services are listed?
4. Enter **`sudo apt install nginx`** and enter **`y`** to install Nginx.
5. Without any further configuration, Nginx is running on your server. Again enter **`sudo ss -atpu`**. How many services are running now?
6. Two of these services are Nginx, one for IPv4 and one for IPv6. To see a list of all available services (including those not running) and their current statuses, enter **`service --status-all`**. What symbol indicates Nginx is running?
7. To stop Nginx, enter **`sudo service nginx stop`**. How can you confirm Nginx is no longer running on your server?

Now you're ready to configure your iptables firewall. Complete the following steps:

8. Begin by looking at what rules are currently in force. Enter the command **`sudo iptables -L`** and then enter your password if necessary. The three chains, or lists of rules, are currently empty. What three chains are listed?

Firewall traffic can be set to either accept traffic that doesn't meet a deny rule, which is called implicit allow, or reject traffic that doesn't meet an accept rule, which is called implicit deny. No restrictions are configured by default, so you need to add some. Complete the following steps:

9. Before making other changes, make sure you allow any current connections to continue. Enter the following command (Figure 10-30):

Figure 10-30 Be careful to enter this command exactly as shown on the last line

```
yourname@capproj3-1:~$ sudo iptables -L
Chain INPUT (policy ACCEPT)
target     prot opt source               destination

Chain FORWARD (policy ACCEPT)
target     prot opt source               destination

Chain OUTPUT (policy ACCEPT)
target     prot opt source               destination
yourname@capproj3-1:~$ sudo iptables -A INPUT -m conntrack --ctstate ESTABLISHED,RELATED -j ACCEPT
```

Source: Canonical Group Limited

sudo iptables -A INPUT -m conntrack --ctstate ESTABLISHED,RELATED -j ACCEPT

10. Enter the **sudo iptables -L** command again to make sure the new rule is listed. Which chain(s) includes the new rule?
11. Next, open port 22 for SSH connections. Enter the following command:

    sudo iptables -A INPUT -p tcp --dport ssh -j ACCEPT

12. The iptables utility automatically knows that SSH runs on port 22 by default, so it opens port 22 when SSH is listed in this command. Sometimes, however, you might want to list the port number itself. Using the command in Step 11 as a guide, what command would you enter to allow HTTPS traffic using the port number instead of the protocol name?
13. Now change the default input policy so it will drop any traffic that doesn't match an accept rule. Enter the following command:

    sudo iptables -P INPUT DROP

14. Enter the **sudo iptables -L** command again to check your changes. Which chain now has a DROP policy? What policy is listed for the other two chains? Using the command in Step 13 as a guide, what command would you enter to change the default forward policy instead?
15. These policies are not persistent, meaning they will be lost the next time you power off the Ubuntu Server VM. To save these rules, you first must export the data to a file. Enter the following command and then enter your password:

    sudo sh -c "iptables-save > /etc/iptables.rules"

16. To confirm your file was saved, change to the /etc directory with the command **cd /etc**. Then, show the directory's contents with the command **ls**.
17. **Take a screenshot** that shows your file in the list; submit this visual with your responses to this project's questions.
18. You won't always have a handy guide to tell you what commands to enter when you want to accomplish a task at the command line. Often, you must do some research. The iptables utility has the option to automatically restore the rules from the rules file each time you power on the system. Look online and find the command that makes this possible. What did you find? What does this command do?
19. Enter the **sudo poweroff** command to shut down the VM. Make some notes on your Wikidot website about your activities in Ubuntu Server for this project.

Solutions to Self-Check Questions

Section 10-1: Security Risks

1. The ability to insert code into a database field labeled "Name" is an example of a(n):
   Answer: b. vulnerability
   Explanation: A weakness of a system, process, or architecture that could lead to compromised information or unauthorized access is known as a **vulnerability**. The act of taking advantage of a vulnerability is known as an exploit or attack. Unauthorized access or use of sensitive data is called a data breach.

2. Which of the following social engineering attack types requires the attacker to spend the most time with the victim?
   Answer: d. Phishing
   Explanation: **Phishing** is communication that appears to come from a legitimate source and requests access or authentication information; to be most effective, phishing typically must build on pre-existing knowledge about the victim, such as knowing the victim's name, the name of their boss, companies they do business with, or similar information. Tailgating, piggybacking, and shoulder surfing are more transient in nature and don't require any existing knowledge about the victim to be successful.

3. You're playing a game on your Xbox when you suddenly get bumped off your Wi-Fi network. You reconnect and start playing, then get bumped off again. What type of attack is most likely the cause?
   Answer: c. Deauth attack
   Explanation: In a **deauth (deauthentication) attack**, the attacker sends faked deauthentication frames to the AP, the client, or both (or as a broadcast to the whole wireless network) to trigger the deauthentication process and knock one or more clients off the wireless network. An on-path attack, also called an MitM (man-in-the-middle) attack, relies on intercepted transmissions. In a well-known exploit called FTP bounce, hackers take advantage of the insecure FTP protocol. DDoS (distributed DoS) attacks are orchestrated through many sources to prevent legitimate users from accessing normal network resources.

Section 10-2: Risk Assessment and Management

4. What is the first step in improving network security?
   Answer: b. Identify risks.
   Explanation: Before spending time and money changing your network security, first **identify your network's current security risks**. The next steps include determining which resources might be harmed if each risk were exploited, developing plans to respond to threats, and documenting next steps.

5. Which assessment type would most likely discover a security risk related to employee on-boarding?
   Answer: b. Process assessment
   Explanation: A **process assessment** is used to identify business processes and evaluate risks related to those processes, such as a security risk in an existing employee on-boarding process. A vendor risk assessment (also called a third-party risk assessment) evaluates security and compliance risks related to suppliers and vendors a company does business with. A threat assessment identifies specific security threats to the network and related risk factors. A posture assessment is a thorough examination of each aspect of the network to determine how it might be compromised.

6. Which security device relies on a TAP or port mirroring?
   Answer: a. NIDS
   Explanation: An **NIDS (network-based intrusion detection system)** sits off to the side of network traffic and is sent duplicates of packets traversing the network from a switch configured with port mirroring or from a TAP device. An HIDS (host-based intrusion detection system) runs on a single computer to detect attacks to that one host. An HIDS solution might also include FIM (file integrity

monitoring), which alerts the system of any changes made to files that shouldn't change, such as operating system files. Like HIDS, an HIPS (host-based intrusion prevention system) protects a specific host and doesn't need access to all network traffic.

Section 10-3: Device Hardening

7. The following ports were listed as open during a recent port scan. Which one is no longer used except by legacy software and should be closed?
   Answer: c. 139
   Explanation: **Ports 137–139** for NetBIOS should be closed to prevent legacy access methods that can be exploited by common malware such as WannaCry ransomware. Port 22 is used by SSH and should be open only if it's needed. Port 53 is used by DNS and must be left open for network connections to work. Port 443 is used by HTTPS and must be left open for web browsing to work.

8. You sent a coworker a .exe file to install an app on their computer. What information should you send your coworker so they can ensure the file has not been tampered with in transit?
   Answer: d. Hash of the file
   Explanation: Hashing is mostly used to ensure data integrity—that is, to verify the data has not been altered. With hashing, your coworker can hash the file and compare the new hash with the expected **hash of the file** that you send. If the hashes match, this indicates the file is exactly the same as the original file. If the output does not match, this indicates the file has likely been altered.

9. What can protect your company from a lawsuit if data is recovered from a discarded device?
   Answer: a. CEED
   Explanation: A **CEED (Certificate of Electronic Equipment Destruction)** is a certificate provided by a disposal service, and it provides legal protection should data later be recovered from your devices. For all companies that provide credit card services, including accepting, storing, processing, or transmitting credit card data, the PCI DSS (Payment Card Industry Data Security Standards) sets requirements for keeping that information secure. The GDPR (General Data Protection Regulation) defines broad protections in the EU (European Union) for PII (personally identifiable information) and standards for how to handle breaches affecting protected data. A DLP (data loss prevention) solution identifies sensitive data on the network and prevents it from being copied or transmitted off the network.